Phishing Analysis

THE GREENHOLT PHISH

LAB WRITEUP

By :
Alexandro Achalma

Descripción: Análisis de un correo falso de transferencia bancaria: cabeceras, SPF/DMARC, IP de origen y adjunto malicioso.

Dificultad: 🟢 Easy

03/10/2026

THE GREENHOLT PHISH

Contexto

Un ejecutivo de ventas de Greenholt PLC reportó un correo sospechoso que decía provenir de un cliente conocido. El mensaje levantó varias alertas: un saludo genérico, una solicitud inesperada relacionada con una transferencia de dinero y un adjunto no solicitado. Según el empleado, este comportamiento no coincidía con la forma habitual de comunicarse de ese cliente.

Ante la duda de que el correo fuera malicioso, el caso se escaló al SOC (*Security Operations Center*) para su investigación. Nuestro rol es el de analista: examinar la muestra del correo (`challenge.eml`) y determinar si es legítimo o si forma parte de un intento de phishing.

Objetivo

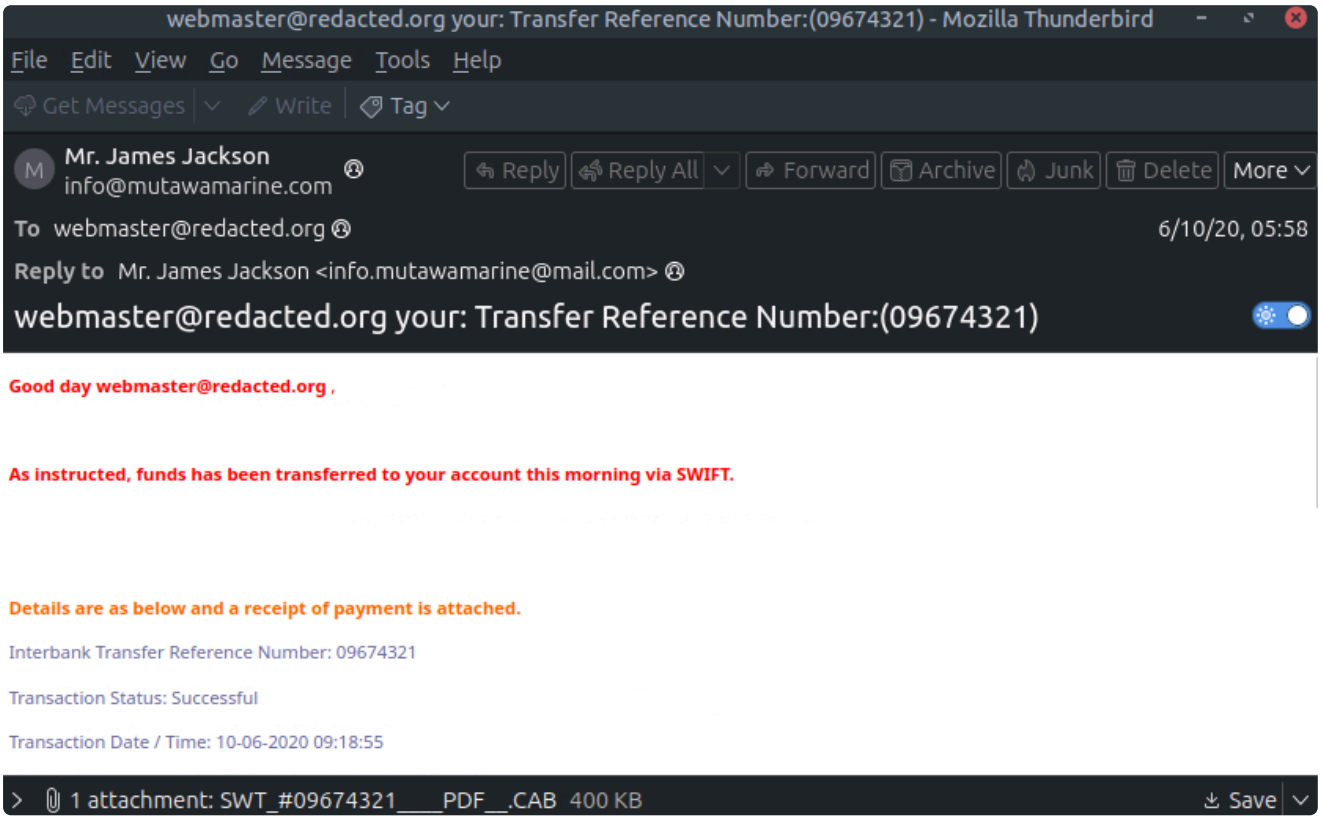
- Analizar el correo proporcionado para identificar y extraer sus **artefactos clave** (remitente, direcciones, IP, adjunto y hash).
- Investigar el **origen del mensaje** a partir de sus cabeceras para determinar su procedencia y autenticidad.
- Utilizar **herramientas de análisis** para evaluar el potencial malicioso del correo y de su adjunto.

Desarrollo

1. Correo

Se abre `challenge.eml` con Thunderbird, que viene preinstalado en la máquina de la room. A simple vista, el mensaje ya presenta varias señales de alerta: un asunto genérico con un número de referencia, un cuerpo con formato descuidado (colores y tamaños inconsistentes), un saludo genérico, y un adjunto cuyo nombre intenta parecer un PDF pero termina en una extensión poco habitual para ese fin.

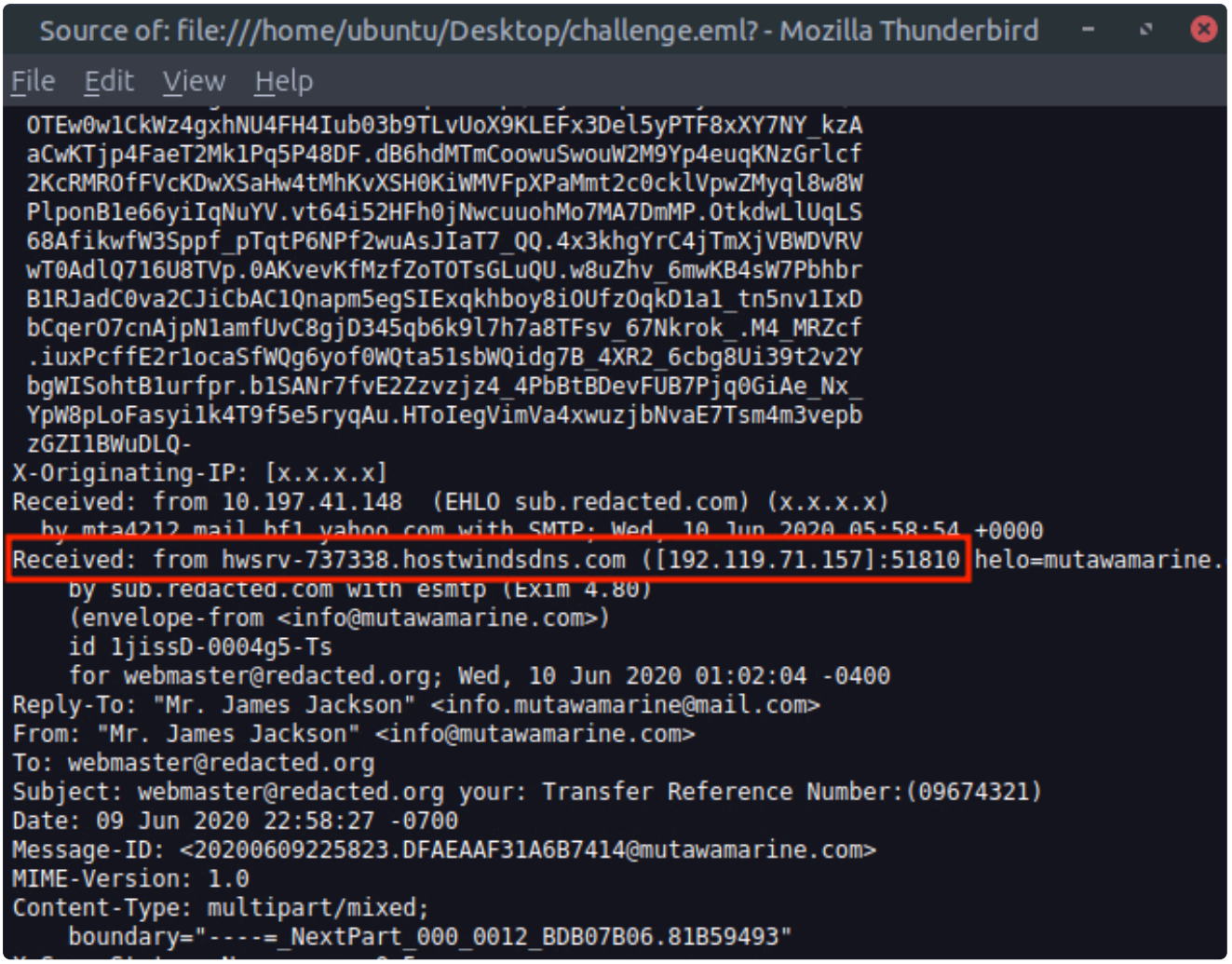
Además, el campo **Reply-To** apunta a una dirección distinta de la del remitente aparente y alojada en un servicio de correo gratuito. Esto es sospechoso, porque si la respuesta no va al dominio del supuesto remitente, es probable que el atacante controle esa otra cuenta y no el dominio que suplanta.



2. Análisis de cabeceras

El contenido visible de un correo es fácil de falsificar, pero las cabeceras dejan rastro del recorrido real. Para verlas se usa *View → Message Source* (`Ctrl+U`).

Las cabeceras `Received` se leen de abajo hacia arriba, porque cada servidor por el que pasa el mensaje añade la suya encima de las anteriores. La más baja corresponde al primer salto, es decir, al servidor desde el que realmente se originó el envío. En ella aparece la dirección IP de origen, que es el dato clave para continuar la investigación.



3. Investigación de la IP de origen

Con la IP identificada, se consulta un servicio WHOIS para saber quién la tiene asignada. Interesa el campo de organización (`OrgName`), que indica el proveedor al que pertenece el rango.

Que la IP pertenezca a un proveedor de hosting compartido y no a la infraestructura del dominio que dice enviar el correo es relevante, porque cualquiera puede contratar un servicio de ese tipo y enviar correo desde él. Es una primera pista de que el origen no coincide con el remitente declarado.

Raw Whois Results for 192.119.71.157

```
#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#


NetRange:       192.119.64.0 - 192.119.127.255
CIDR:           192.119.64.0/18
NetName:        HOSTWINDS-18-2
NetHandle:      NET-192-119-64-0-1
Parent:         NET192 (NET-192-0-0-0-0)
NetType:        Direct Allocation
OriginAS:
Organization:   HostPapa (HOSTP-7)
RegDate:        2012-11-12
Updated:        2026-05-13
Comment:        Geofeed https://geofeeds.oniaas.io/geofeeds.csv
Ref:            https://rdap.arin.net/registry/ip/192.119.64.0

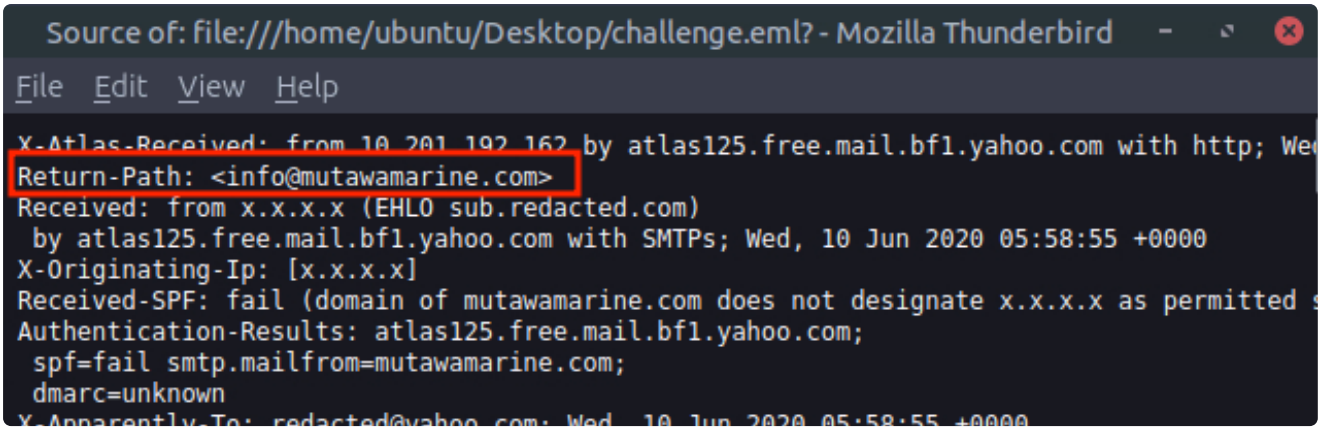

OrgName:        HostPapa
OrgId:          HOSTP-7
Address:        325 Delaware Avenue
Address:        Suite 300
City:           Buffalo
StateProv:      NY
PostalCode:     14202
Country:        US
```

4. Return-Path y discrepancias de identidad

Volviendo a las cabeceras, se revisa el campo `Return-Path`, que indica a dónde se enviarían los rebotes (*bounces*) del mensaje y es el que se valida en los controles SPF. Se compara con el remitente visible (`From`) y con el `Reply-To` observado antes, para ver si las identidades son coherentes o si el atacante mezcla direcciones distintas para evadir filtros y desviar las respuestas.

En esta misma zona se encuentra el resultado de la validación SPF que hizo el servidor receptor (`Received-SPF`) y el resumen en `Authentication-Results`. Allí se ve que la validación **falló**, es decir, el dominio remitente no autoriza a esa

IP a enviar correo en su nombre. Esto confirma que el mensaje no proviene de la infraestructura legítima del dominio que suplanta.



5. Verificación de la política SPF del dominio

Qué es: SPF (*Sender Policy Framework*) es un registro DNS de tipo TXT donde un dominio declara qué servidores están autorizados a enviar correo en su nombre.

Cómo se revisa: se consulta el registro del dominio remitente con una herramienta de inspección SPF. El registro termina con un *qualifier* que define qué hacer con los remitentes no autorizados. Por ejemplo, `-all` indica rechazo estricto (hard fail), mientras que `~all` indica fallo suave (soft fail) y `?all` es neutral.

Por qué importa: el dominio sí tiene una política definida y delega su envío en un proveedor de correo concreto. La IP de origen del correo no está dentro de esos rangos autorizados, lo que explica el fallo visto en las cabeceras. Un registro SPF por sí solo no impide la entrega, pero es un indicador sólido de suplantación cuando falla.

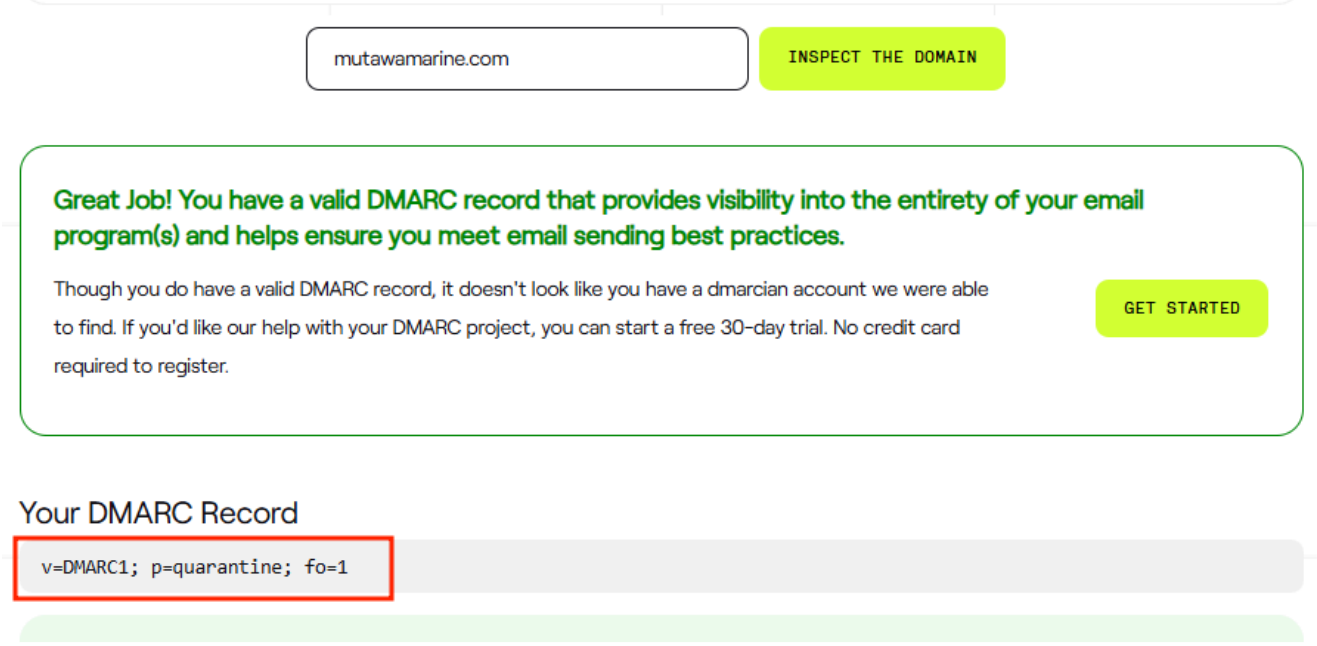


6. Verificación de la política DMARC

Qué es: DMARC (*Domain-based Message Authentication, Reporting & Conformance*) se apoya en SPF y DKIM, y le indica al servidor receptor qué hacer cuando un mensaje falla ambas validaciones: no hacer nada (`none`), enviarlo a cuarentena (`quarantine`) o rechazarlo (`reject`).

Cómo se revisa: se consulta el registro DMARC del dominio con una herramienta de inspección, que además muestra las etiquetas de configuración, como la política aplicada (`p=`) y las opciones de reporte de fallos (`fo=`).

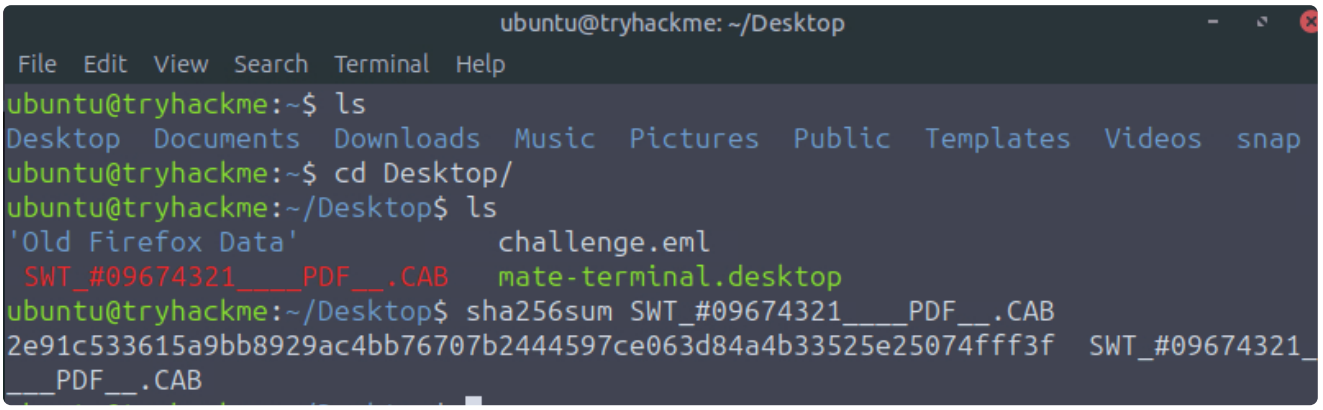
Por qué importa: que el dominio tenga una política DMARC activa indica que su titular se preocupa por la suplantación. Aun así, la protección solo es efectiva si el receptor la aplica, por lo que el correo pudo haber sido tratado de forma distinta según el proveedor que lo recibió.



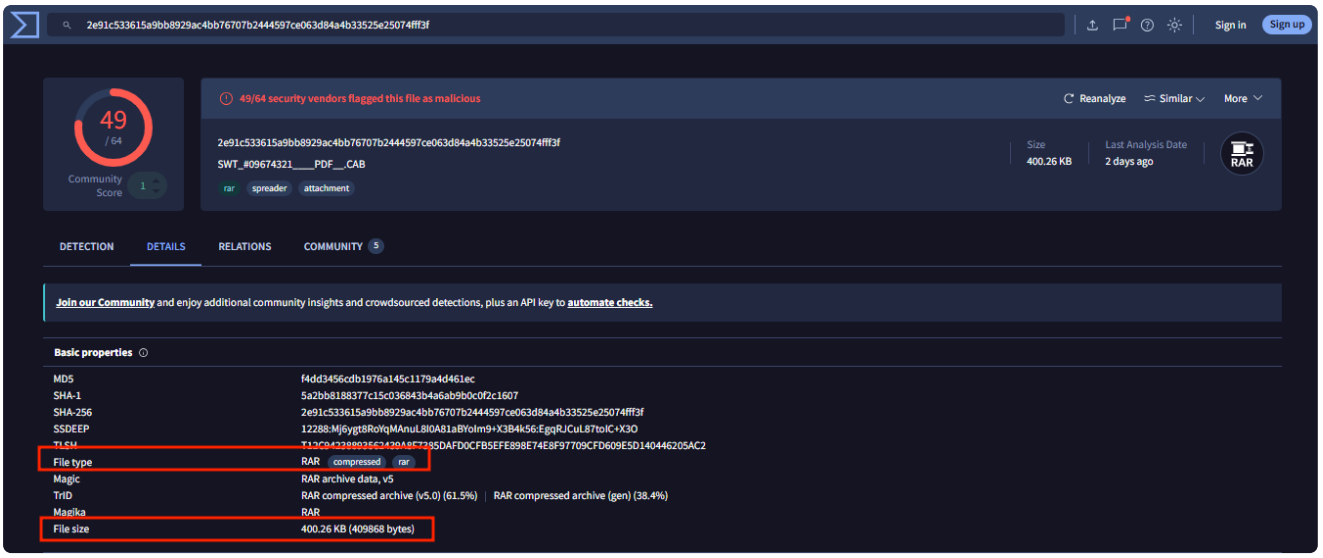
7. Análisis del adjunto

El adjunto es el elemento más peligroso del correo, así que nunca se abre ni se ejecuta. En su lugar, se trabaja con su huella digital:

1. Desde la terminal, en la carpeta donde está el archivo (`Desktop`), se lista el contenido con `ls` y se calcula su hash con `sha256sum <archivo>`. El hash identifica al archivo de forma inequívoca sin necesidad de ejecutarlo.
2. Este valor se busca en **VirusTotal**, que lo contrasta con una base de datos de análisis de decenas de motores antivirus.



VirusTotal marca el archivo como malicioso por una amplia mayoría de motores. En la pestaña **Details** se comprueba el tipo de archivo real (basado en su firma o *magic number*, no en el nombre) y su tamaño. Aquí se observa una incoherencia clave: **la extensión con la que se presenta el archivo no corresponde con su formato real**. Es una táctica de enmascaramiento para que la víctima crea que abre un documento inofensivo, cuando en realidad se trata de otro tipo de contenedor.



8. Conclusión

El correo es un intento de **phishing con adjunto malicioso**. Las evidencias que lo sostienen son:

- Contenido genérico y de aspecto descuidado, con un gancho económico.
- Discrepancia entre el remitente aparente, el `Reply-To` y el origen real del envío.
- IP de origen alojada en un proveedor de hosting no relacionado con el dominio suplantado.
- Fallo de validación SPF frente a una política que sí existe en el dominio.
- Adjunto con extensión engañosa, cuyo formato real no coincide, y detectado como malicioso por la mayoría de motores.

Recomendaciones: bloquear el dominio y la IP en el filtro de correo, eliminar el mensaje de los buzones afectados, avisar a los usuarios, y reforzar la formación en reconocimiento de phishing y la revisión de extensiones de adjuntos.

Referencias

- TryHackMe: *The Greenholt Phish*. https://tryhackme.com/room/phishingemails5fgjlzxc
- AbuseIPDB. https://www.abuseipdb.com/
- DMARCIAN. https://dmarcian.com/dmarc-tools/
- VirusTotal. https://www.virustotal.com/gui/home/upload